

Informe Pericial Forense: Proyecto 5: Incident on Linux Server I

Grupo 3 — Análisis Forense Digital

1. Juramento y Declaración de Abstención y Tacha

Los peritos firmantes declaran bajo juramento que el presente informe ha sido elaborado con objetividad, imparcialidad y rigor técnico, sin que concurra ninguna causa de abstención o tacha que pudiera comprometer la independencia del análisis realizado. El equipo no mantiene ninguna relación personal ni profesional con las partes implicadas en el incidente que pudiera influir en las conclusiones aquí expuestas.

2. Palabras Clave

- **Vulnerabilidad crítica:** Fallo grave en un sistema informático que permite a un atacante externo realizar acciones no autorizadas sobre él.
- **Inyección de comandos del sistema operativo (CWE-78):** Tipo de ataque en el que un intruso introduce instrucciones maliciosas en un campo de texto de una aplicación web, engañando al servidor para que las ejecute como si fueran órdenes legítimas del sistema.
- **Aplicación web:** Programa informático accesible desde un navegador de internet, como un formulario o una tienda online.
- **PHP:** Lenguaje de programación ampliamente utilizado para construir aplicaciones web que se ejecutan en el servidor.
- **Exfiltración de datos:** Extracción no autorizada de información confidencial desde un sistema informático hacia el exterior.
- **Imagen de disco:** Copia exacta e íntegra del contenido de un disco duro, utilizada en análisis forense para estudiar el sistema sin alterar el original.
- **Volcado de memoria RAM:** Captura instantánea del contenido de la memoria activa de un ordenador en un momento concreto, que puede revelar programas en ejecución, contraseñas o actividad reciente.
- **Registro de acceso web (access.registro):** Archivo que guarda automáticamente un historial de todas las peticiones recibidas por un servidor web, incluyendo la dirección IP del visitante, la fecha y hora, y el recurso solicitado.
- **Servidor Linux:** Ordenador que utiliza el sistema operativo Linux para ofrecer servicios en red, muy común en entornos empresariales y centros de datos.
- **Cadena de custodia:** Proceso de documentación que garantiza que las evidencias digitales no han sido manipuladas desde su recogida hasta su análisis.

3. Índice de Figuras

- Figura 1. Comprobación de integridad de hashes en PowerShell.

- Figura 2. Extracto del archivo access.registro con peticiones a ping.php.
- Figura 3. Localización de ping.php en FTK Imager.
- Figura 4. Contenido del archivo ping.php visualizado en Visual Studio Code.
- Figura 5. Localización de passwd.txt en FTK Imager.
- Figura 6. Contenido del archivo passwd.txt.
- Figura 7. Propiedades y fecha de modificación de passwd.txt.
- Figura 8. Análisis de cadenas en la captura de memoria RAM.
- Figura 9. registro de Samba con la IP del atacante en FTK Imager.
- Figura 10. Extracto del access.registro con información del cliente del atacante.

4. Resumen Ejecutivo

El presente informe documenta el análisis forense realizado sobre un servidor Linux comprometido mediante la explotación de una vulnerabilidad crítica de inyección de comandos del sistema operativo (CWE-78) presente en una aplicación web desarrollada en PHP. El atacante, cuya dirección IP es 192.168.1.6, utilizó esta vulnerabilidad para generar un volcado de credenciales del sistema y, presumiblemente, exfiltrarlo. El análisis de la imagen de disco y la captura de memoria RAM ha permitido reconstruir el vector de ataque, identificar los artefactos creados por el intruso y proponer medidas correctivas.

5. Introducción

5.1 Antecedentes

El técnico responsable del centro de datos de la empresa afectada, recibió una notificación de posible incidente de seguridad que alertaba sobre la exfiltración de datos sensibles desde un servidor interno. Ante la gravedad del incidente, la empresa contrató al equipo pericial para determinar el alcance del ataque, identificar al equipo responsable y proponer medidas de remediación.

5.2 Objetivos

El encargo pericial persigue los siguientes objetivos:

1. Identificar la vulnerabilidad de la aplicación web que fue explotada.
2. Determinar la dirección IP, el cliente de navegación y el sistema operativo del atacante.
3. Descubrir qué datos fueron exfiltrados del servidor comprometido.
4. Analizar por qué el archivo original de contraseñas no muestra actividad durante el incidente.
5. Proponer medidas de remediación para corregir la vulnerabilidad explotada.

6. Fuentes de Información

Las evidencias digitales proporcionadas por el cliente para el análisis son las siguientes:

Evidencia	Descripción
Imagen de disco	Imagen forense del servidor Linux comprometido
Volcado de memoria RAM	Captura de la memoria volátil del sistema en el momento del incidente

Evidencia	Descripción
Perfil de memoria	Perfil necesario para el análisis del volcado con Volatility
Archivo de sumas de verificación	Archivo hashes_sha256.txt con los valores hash SHA-256 de las evidencias

6.1 Adquisición de Evidencias

Antes de iniciar cualquier análisis, se procedió a verificar la integridad de las evidencias comparando los valores hash SHA-256 proporcionados por el cliente con los calculados sobre los archivos recibidos. Esta verificación se realizó mediante PowerShell y los resultados confirmaron que las evidencias no habían sido alteradas desde su adquisición, garantizando así la cadena de custodia.

```
PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5> Get-FileHash -Path .\imagen_disco.dd -Algorithm sha256
Algorithm Hash Path
-----
SHA256 9F12B2DACE6CFEBC1B6F956FC231E199C00F39E05D5028688F28404353706509 C:\Users\mid_ex882\Desktop\Ci...

PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5> Get-FileHash -Path .\imagen_disco.dd.zip -Algorithm sha256
Algorithm Hash Path
-----
SHA256 B0189203FA682FD88ED3C52A3723AC46AB89GA2FBBE4DAF49ED02288C703876 C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5\imagen_disco.dd.zip

PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5> Get-FileHash -Path .\captura_ram.lime -Algorithm sha256
Algorithm Hash Path
-----
SHA256 8F5D751288808450E29888D27F22451DD2AE1580FC1CB808974F360E9A88FF05 C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5\captura_ram.lime

PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5> Get-FileHash -Path .\captura_ram.lime.zip -Algorithm sha256
Algorithm Hash Path
-----
SHA256 532D3D95260753029D7C9ADE15E0DCA86988FE7E808D7001D9F923822D0F003F C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5\captura_ram.lime.zip

PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5> Get-FileHash -Path .\perfil_memoria.zip -Algorithm sha256
Algorithm Hash Path
-----
SHA256 188308973223B8A8233AA1581BCCD35BEF6C678B29E671B3FE3A7EE5EA24B076 C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5\perfil_memoria.zip

PS C:\Users\mid_ex882\Desktop\Ciberseguridad\GRUPO_3\25-26-ciberseguridad-grupo-3\Análisis_forense\UD5\Proyecto 5>
```

(Figura 1) Comprobación de sumas de integridad mediante herramienta Get-FileHash de windows Powershell

7. Análisis

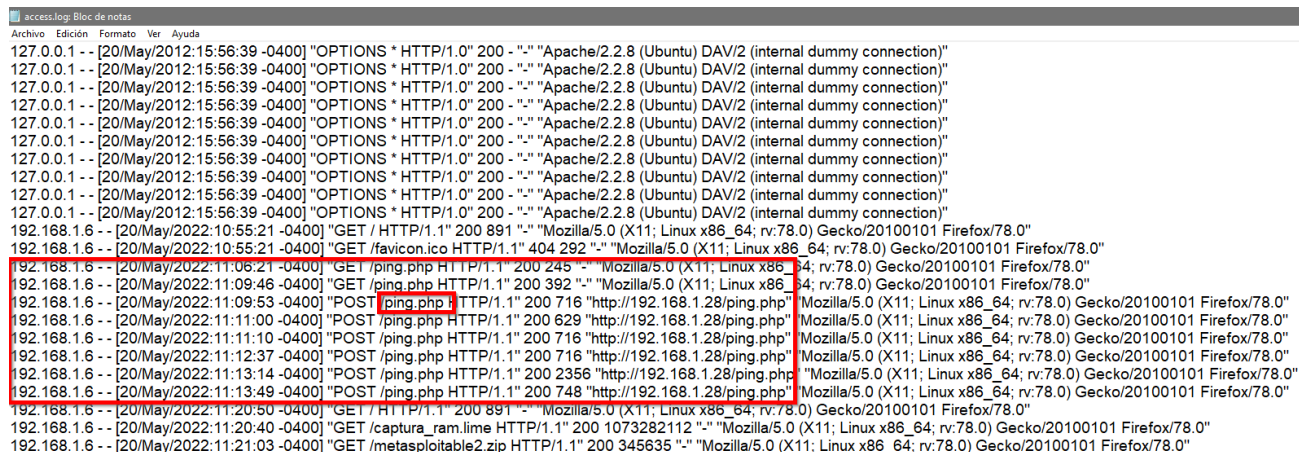
7.1 Herramientas Utilizadas

Herramienta	Versión	Uso
Exterro FTK Imager	8.2.0.26	Análisis de la imagen de disco
Volatility	2.x	Análisis del volcado de memoria RAM
PowerShell	Integrado en Windows	Verificación de hashes SHA-256
Visual Studio Code	Actual	Revisión del contenido de archivos extraídos
Bloc de notas (Windows)	Integrado	Revisión de registros de texto plano

7.2 Procesos

7.2.1 Análisis de la vulnerabilidad web

La investigación comenzó con el análisis del archivo de registro de accesos de Apache, localizado en /var/registro/apache2/access.registro. En dicho archivo se observaron múltiples peticiones dirigidas al recurso ping.php, lo que motivó una inspección directa del archivo.

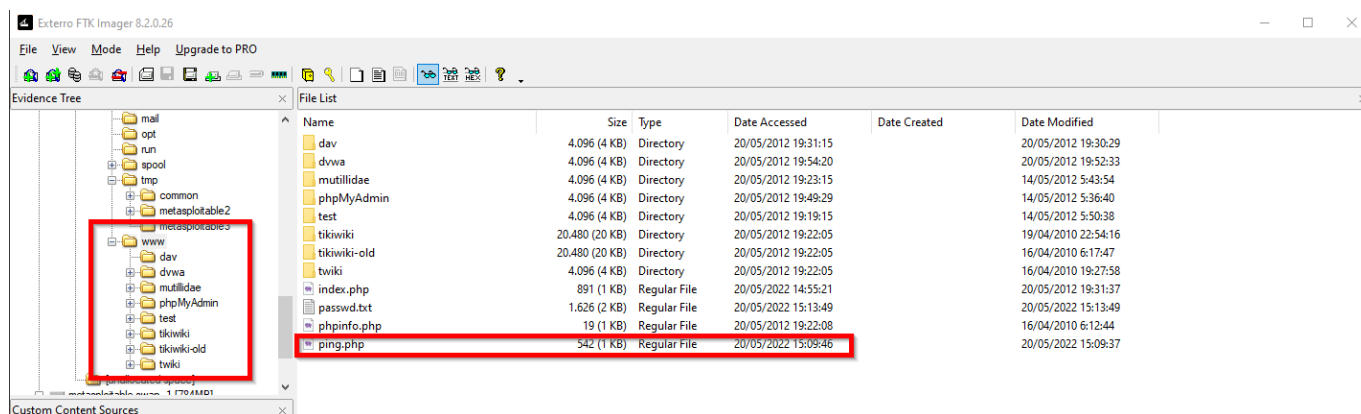


```

127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
127.0.0.1 -- [20/May/2012:15:56:39 -0400] "OPTIONS * HTTP/1.0" 200 - "-" "Apache/2.2.8 (Ubuntu) DAV/2 (internal dummy connection)"
192.168.1.6 -- [20/May/2012:10:55:21 -0400] "GET / HTTP/1.1" 200 891 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:10:55:21 -0400] "GET /favicon.ico HTTP/1.1" 404 292 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:09:46 -0400] "GET /ping.php HTTP/1.1" 200 245 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:09:53 -0400] "POST /ping.php HTTP/1.1" 200 716 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:11:00 -0400] "POST /ping.php HTTP/1.1" 200 629 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:11:10 -0400] "POST /ping.php HTTP/1.1" 200 716 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:12:37 -0400] "POST /ping.php HTTP/1.1" 200 716 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:13:14 -0400] "POST /ping.php HTTP/1.1" 200 2356 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:13:49 -0400] "POST /ping.php HTTP/1.1" 200 748 "http://192.168.1.28/ping.php" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:20:50 -0400] "GET / HTTP/1.1" 200 891 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:20:40 -0400] "GET /captura_ram.lime HTTP/1.1" 200 1073282112 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
192.168.1.6 -- [20/May/2012:11:21:03 -0400] "GET /metasploitable2.zip HTTP/1.1" 200 345635 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"

```

(Figura 2) Registro de peticiones a ese archivo



Name	Size	Type	Date Accessed	Date Created	Date Modified
dav	4.096 (4 KB)	Directory	20/05/2012 19:31:15		20/05/2012 19:30:29
dvwa	4.096 (4 KB)	Directory	20/05/2012 19:54:20		20/05/2012 19:52:33
mutillidae	4.096 (4 KB)	Directory	20/05/2012 19:23:15		14/05/2012 5:43:54
phpMyAdmin	4.096 (4 KB)	Directory	20/05/2012 19:49:29		14/05/2012 5:36:40
test	4.096 (4 KB)	Directory	20/05/2012 19:19:15		14/05/2012 5:50:38
tikiwiki	20.480 (20 KB)	Directory	20/05/2012 19:22:05		19/04/2010 22:54:16
tikiwiki-old	20.480 (20 KB)	Directory	20/05/2012 19:22:05		16/04/2010 6:17:47
twiki	4.096 (4 KB)	Directory	20/05/2012 19:22:05		16/04/2010 19:27:58
index.php	891 (1 KB)	Regular File	20/05/2012 14:55:21		20/05/2012 19:31:37
passwd.txt	1.626 (2 KB)	Regular File	20/05/2012 15:13:49		20/05/2012 15:13:49
phpinfo.php	19 (1 KB)	Regular File	20/05/2012 19:22:08		16/04/2010 6:12:44
ping.php	542 (1 KB)	Regular File	20/05/2012 15:09:46		20/05/2012 15:09:37

(Figura 3) Localización del archivo

El archivo ping.php, localizado en el directorio raíz del servidor web, con ruta /root/var/www/ping.php , contiene el siguiente fragmento de código en su línea 19:

```
echo(system('ping -c 1 ' . $_POST['ping']));
```

El valor recibido a través del parámetro ping del formulario se concatena directamente en una llamada a la función system() de PHP sin ningún tipo de validación ni saneamiento previo. Esto constituye una vulnerabilidad de inyección de comandos del sistema operativo, clasificada bajo el identificador CWE-78 (Improper Neutralization of Special Elements used in an OS Command).

```
C: > Users > mid_ex882 > Desktop > ping.php
1  <!DOCTYPE html>
2  <html>
3  |   <head>
4  |       <meta charset="UTF-8"/>
5  |       <title>PING</title>
6  |   </head>
7  |   <body>
8  |       <form action="ping.php" method="post" />
9  |           <label for="ping">IP: </label><input type="text" name="ping"
10 |              value="<?php echo(isset($_POST['ping']) ? $_POST['ping'] : ''); ?>" />
11 |           <br/>
12 |           <input type="submit" value="enviar" />
13 |           <br/>
14 |           <br/>
15 |       </form>
16 <?php
17
18 if (isset($_POST['ping'])) {
19 |     echo(system('ping -c 1 ' . $_POST['ping']));
20 | }
21
22 ?>
23 </body>
24 </html>
25
```

(Figura 4) Código completo del archivo ping.php

En lugar de ejecutar únicamente el comando ping, el servidor ejecutaría cualquier instrucción adicional con los mismos privilegios que el proceso web, permitiendo desde la lectura de archivos sensibles hasta el establecimiento de un acceso remoto completo. La vulnerabilidad guarda similitud con CVE-2012-1823, que afecta a PHP en modo CGI, aunque su explotación en este caso no se basa necesariamente en dicho vector, sino en una mala práctica de programación del propio desarrollador de la aplicación.

7.2.2 Análisis de la identidad del atacante

El análisis del archivo access.registro permitió identificar de forma inequívoca los datos del agente que interactuó con la vulnerabilidad. (Figura 10)

Campo	Valor
Dirección IP del atacante	192.168.1.6
Navegador utilizado	Firefox 78.0 ESR
Sistema operativo	Linux x86_64 (probablemente Kali Linux)

La dirección IP pertenece al rango de red local, lo que sugiere que el atacante operó desde dentro de la misma red o a través de un sistema comprometido en la misma subred.

8. Limitaciones

Durante el análisis se identificaron las siguientes limitaciones que podrían condicionar parcialmente las conclusiones:

1. La dirección IP del atacante (192.168.1.6) pertenece al espacio de red privado RFC 1918, lo que impide atribuir el ataque a una ubicación geográfica o entidad externa de forma directa. No es posible descartar que dicha IP corresponda a una máquina comprometida usada como punto de salto.

2. El registro de Samba estaba vacío y no se ha encontrado más actividad relacionada en volcado de memoria, por lo que no se puede confirmar con certeza si la exfiltración se completó a través de ese protocolo o si se empleó otro vector de transferencia no registrado en los artefactos disponibles.
3. El análisis de la memoria RAM proporciona indicios del método empleado, pero las cadenas recuperadas no constituyen por sí solas prueba definitiva sin un análisis de proceso más profundo mediante Volatility.

9. Conclusiones

El análisis forense realizado permite establecer con un alto grado de certeza que:

1. El servidor fue comprometido a través de una vulnerabilidad de inyección de comandos del sistema operativo presente en el archivo ping.php.
2. El atacante operó desde la dirección IP 192.168.1.6 utilizando Firefox 78.0 sobre un sistema Linux x86_64.
3. El atacante aprovechó la ausencia de validación de entradas en dicho archivo para ejecutar comandos arbitrarios en el servidor con los privilegios del proceso web.
4. Como consecuencia de la explotación, se generó el archivo passwd.txt con el volcado de las credenciales del sistema, cuya fecha de modificación coincide con los eventos registrados en el registro de Apache. El archivo original /etc/passwd no muestra actividad porque fue únicamente leído, operación que no deja huella en sus metadatos de modificación.

10. Anexos

Anexo 1. Sobre el Perito

El presente informe ha sido elaborado por los integrantes del Grupo 3 del módulo de Análisis Forense Informático, en el marco de la asignatura correspondiente al ciclo formativo de grado superior. Los autores actúan en calidad de peritos designados a efectos académicos y no ostentan ningún interés particular en el resultado del análisis.

Anexo 2. Sumas de Verificación

La integridad de las evidencias analizadas fue verificada correctamente. Los valores obtenidos coincidieron con los registrados en el archivo hashes_sha256.txt proporcionado por el cliente, confirmando que las evidencias no fueron modificadas tras su adquisición.

Evidencia	Estado de integridad
Imagen de disco del servidor	Verificada — hash coincidente
Volcado de memoria RAM	Verificada — hash coincidente
Perfil de memoria	Verificada — hash coincidente

[enlace al archivo de comprobación](#)

Anexo 3. Índice de Hallazgos

Hallazgo 1: ping.php

- **Ruta:** /var/www/html/ping.php
- **Descripción:** Archivo PHP con vulnerabilidad de inyección de comandos del sistema operativo (CWE-78). La entrada del usuario se concatena directamente en una llamada a system() sin saneamiento.
- **Relevancia:** Vector de ataque principal utilizado por el intruso.

Hallazgo 2: passwd.txt

- **Ruta:** /var/www/html/passwd.txt
- **Descripción:** Archivo de texto generado por el atacante que contiene el volcado de credenciales del sistema obtenido a través de la vulnerabilidad.
- **Relevancia:** Evidencia directa de los datos exfiltrados.

Hallazgo 3: access.log

- **Ruta:** /var/registro/apache2/access.registro
- **Descripción:** Registro de accesos del servidor web Apache. Contiene las peticiones realizadas por el atacante, incluyendo su dirección IP, agente de usuario y marcas temporales.
- **Relevancia:** Fuente principal para la atribución del ataque.

Hallazgo 4: registro de Samba

- **Ruta:** /var/registro/samba/ (archivo correspondiente a la IP 192.168.1.6)
- **Descripción:** Registro de actividad del servicio Samba que recoge el intento de conexión desde la IP del atacante. El archivo se encontraba vacío.
- **Relevancia:** Indica un posible intento de exfiltración a través de SMB, aunque no se puede confirmar su consumación.

Hallazgo 5: Cadenas en memoria RAM

- **Fuente:** Volcado de memoria RAM analizado con Volatility.
- **Descripción:** Cadenas de texto recuperadas de la memoria que corresponden con los parámetros probablemente utilizados por el atacante para crear passwd.txt y recuperarlo del servidor.
- **Relevancia:** Corroborar el método de explotación y la intención de exfiltración.